

# norm

## NEN-EN 40000-1-3

Cybersecurity requirements for products  
with digital elements - Part 1-3:  
Vulnerability Handling

Publicatie uitsluitend voor commentaar

december 2025

ICS 35.030

Commentaar vóór 2026-02-05

Als Europees normontwerp is gepubliceerd: prEN 40000-1-3:2025,IDT

Definitief vastgestelde normen zullen als Nederlandse norm gelden. Daarom wordt dit normontwerp in Nederland voor commentaar gepubliceerd. Op het ontwerp ingebracht commentaar zal aan de bevoegde normcommissie worden voorgelegd die hiermee rekening zal houden bij de bepaling van de Nederlandse stem. Indien er geen bezwaar bij NEN wordt gebracht, kan dat leiden tot ongewijzigde definitieve vaststelling van het ontwerp als norm.

Van Europese normen bestaan drie officiële versies: Engels, Frans en Duits. Voor Nederland zal de Engelse versie gelden. Daarnaast kan er gekozen worden voor een andere geautoriseerde versie in het Nederlands.

Normcommissie 381027 'Cybersecurity & Privacy'



**THIS PUBLICATION IS COPYRIGHT PROTECTED**

**DEZE PUBLICATIE IS AUTEURSRECHTELIJK BESCHERMD**

Apart from exceptions provided by the law, nothing from this publication may be duplicated and/or published by means of photocopy, microfilm, storage in computer files or otherwise, which also applies to full or partial processing, without the written consent of Stichting Koninklijk Nederlands Normalisatie Instituut.

Stichting Koninklijk Nederlands Normalisatie Instituut shall, with the exclusion of any other beneficiary, collect payments owed by third parties for duplication and/or act in and out of law, where this authority is not transferred or falls by right to Stichting Reprerecht.

Auteursrecht voorbehouden. Behoudens uitzondering door de wet gesteld mag zonder schriftelijke toestemming van Stichting Koninklijk Nederlands Normalisatie Instituut niets uit deze uitgave worden verveelvoudigd en/of openbaar gemaakt door middel van fotokopie, microfilm, opslag in computerbestanden of anderszins, hetgeen ook van toepassing is op gehele of gedeeltelijke bewerking.

Stichting Koninklijk Nederlands Normalisatie Instituut is met uitsluiting van ieder ander gerechtigd de door derden verschuldigde vergoedingen voor verveelvoudiging te innen en/of daartoe in en buiten rechte op te treden, voor zover deze bevoegdheid niet is overgedragen c.q. rechtens toekomt aan Stichting Reprerecht.

Although the utmost care has been taken with this publication, errors and omissions cannot be entirely excluded. Stichting Koninklijk Nederlands Normalisatie Instituut and/or the members of the committees therefore accept no liability, not even for direct or indirect damage, occurring due to or in relation with the application of publications issued by Stichting Koninklijk Nederlands Normalisatie Instituut.

Hoewel bij deze uitgave de uiterste zorg is nagestreefd, kunnen fouten en onvolledigheden niet geheel worden uitgesloten. Stichting Koninklijk Nederlands Normalisatie Instituut en/of de leden van de commissies aanvaarden derhalve geen enkele aansprakelijkheid, ook niet voor directe of indirecte schade, ontstaan door of verband houdend met toepassing van door Stichting Koninklijk Nederlands Normalisatie Instituut gepubliceerde uitgaven.

Ontwerp  
Draft

EUROPEAN STANDARD  
NORME EUROPÉENNE  
EUROPÄISCHE NORM

**DRAFT**  
**prEN 40000-1-3**

December 2025

ICS 35.030

English version

**Cybersecurity requirements for products with digital  
elements - Part 1-3: Vulnerability Handling**

Cybersicherheitsanforderungen für Produkte mit  
digitalen Bestandteilen - Umgang mit Schwachstellen

This draft European Standard is submitted to CEN members for enquiry. It has been drawn up by the Technical Committee CEN/CLC/JTC 13.

If this draft becomes a European Standard, CEN and CENELEC members are bound to comply with the CEN/CENELEC Internal Regulations which stipulate the conditions for giving this European Standard the status of a national standard without any alteration.

This draft European Standard was established by CEN and CENELEC in three official versions (English, French, German). A version in any other language made by translation under the responsibility of a CEN and CENELEC member into its own language and notified to the CEN-CENELEC Management Centre has the same status as the official versions.

CEN and CENELEC members are the national standards bodies and national electrotechnical committees of Austria, Belgium, Bulgaria, Croatia, Cyprus, Czech Republic, Denmark, Estonia, Finland, France, Germany, Greece, Hungary, Iceland, Ireland, Italy, Latvia, Lithuania, Luxembourg, Malta, Netherlands, Norway, Poland, Portugal, Republic of North Macedonia, Romania, Serbia, Slovakia, Slovenia, Spain, Sweden, Switzerland, Türkiye and United Kingdom.

Recipients of this draft are invited to submit, with their comments, notification of any relevant patent rights of which they are aware and to provide supporting documentation. Recipients of this draft are invited to submit, with their comments, notification of any relevant patent rights of which they are aware and to provide supporting documentation.

**Warning** : This document is not a European Standard. It is distributed for review and comments. It is subject to change without notice and shall not be referred to as a European Standard.



**CEN-CENELEC Management Centre:  
Rue de la Science 23, B-1040 Brussels**

| <b>Contents</b>                                                    | <b>Page</b> |
|--------------------------------------------------------------------|-------------|
| European foreword .....                                            | 4           |
| Introduction .....                                                 | 5           |
| 1 Scope .....                                                      | 7           |
| 2 Normative references .....                                       | 7           |
| 3 Terms and definitions .....                                      | 7           |
| 4 General .....                                                    | 8           |
| 4.1 Structure of this document .....                               | 8           |
| 4.2 Relationships with other international standards .....         | 8           |
| 5 Vulnerability handling .....                                     | 9           |
| 5.1 General .....                                                  | 9           |
| 5.2 [APP] Applicability .....                                      | 9           |
| 5.2.1 General .....                                                | 10          |
| 5.2.2 [APP-1] Requirement enhancement applicability .....          | 10          |
| 5.3 [PRE] Preparation .....                                        | 10          |
| 5.3.1 General .....                                                | 10          |
| 5.3.2 [PRE-1] Policy on vulnerability handling .....               | 10          |
| 5.3.3 [PRE-2] Policy on coordinated vulnerability disclosure ..... | 12          |
| 5.3.4 [PRE-3] Operational security .....                           | 14          |
| 5.3.5 [PRE-4] On-going communication .....                         | 15          |
| 5.3.6 [PRE-5] Secure communication .....                           | 16          |
| 5.3.7 [PRE-6] Product identification .....                         | 17          |
| 5.3.8 [PRE-7] Identification of software components .....          | 18          |
| 5.3.9 [PRE-8] Identification of hardware components .....          | 20          |
| 5.3.10 [PRE-9] Planning regular test and reviews .....             | 21          |
| 5.3.11 [PRE-10] Mechanisms for distribution .....                  | 22          |
| 5.4 [RCP] Receipt .....                                            | 22          |
| 5.4.1 General .....                                                | 22          |
| 5.4.2 [RCP-1] Capability to receive reports .....                  | 23          |
| 5.4.3 [RCP-2] Monitoring .....                                     | 24          |
| 5.4.4 [RCP-3] Potentially impacted software components .....       | 25          |
| 5.4.5 [RCP-4] Potentially impacted hardware components .....       | 25          |
| 5.4.6 [RCP-5] Coordinator involvement .....                        | 26          |
| 5.4.7 [RCP-6] Performing regular tests .....                       | 26          |
| 5.4.8 [RCP-7] Performing regular reviews .....                     | 27          |
| 5.5 [VRF] Verification .....                                       | 28          |
| 5.5.1 General .....                                                | 28          |
| 5.5.2 [VRF-1] Initial assessment and verification .....            | 28          |
| 5.5.3 [VRF-2] Vulnerability risk assessment .....                  | 29          |
| 5.6 [RMD] Remediation .....                                        | 30          |
| 5.6.1 General .....                                                | 30          |
| 5.6.2 [RMD-1] Remediation decision .....                           | 30          |
| 5.6.3 [RMD-2] Remediation development .....                        | 30          |
| 5.6.4 [RMD-3] Remediation test .....                               | 31          |
| 5.7 [RLS] Release .....                                            | 32          |
| 5.7.1 General .....                                                | 32          |
| 5.7.2 [RLS-1] Security update release .....                        | 32          |
| 5.7.3 [RLS-2] Release information .....                            | 33          |
| 5.8 [PRA] Post-release .....                                       | 35          |
| 5.8.1 General .....                                                | 35          |
| 5.8.2 [PRA-1] Post-release actions .....                           | 35          |

|                                                                                                                                                                                                                                                                                                                                                                                                                                             |           |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>Annex ZA (informative) Relationship between this European Standard and the essential cybersecurity requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) aimed to be covered .....</b> | <b>36</b> |
| <b>Bibliography .....</b>                                                                                                                                                                                                                                                                                                                                                                                                                   | <b>37</b> |

Ontwerp  
Draft

## prEN 40000-1-3 (E)

### European foreword

This document (prEN 40000-1-3:2026) has been prepared by Technical Committee CEN/CLC JTC 13 "Cybersecurity and Data Protection", the secretariat of which is held by DIN.

This document is currently submitted to the CEN Enquiry.

This document has been prepared under a standardization request addressed to CEN-CENELEC by the European Commission. The Standing Committee of the EFTA States subsequently approves these requests for its Member States.

For the relationship with EU Legislation, see informative [Annex ZA](#), which is an integral part of this document.

Ontwerp  
Draft

## Introduction

Vulnerabilities are likely to emerge over time during the life cycle of a product with digital elements (hereinafter referred to as "product"), including its software and hardware components, despite adherence to cybersecurity principles defined in [prEN 40000-1-2 \[1\]](#).

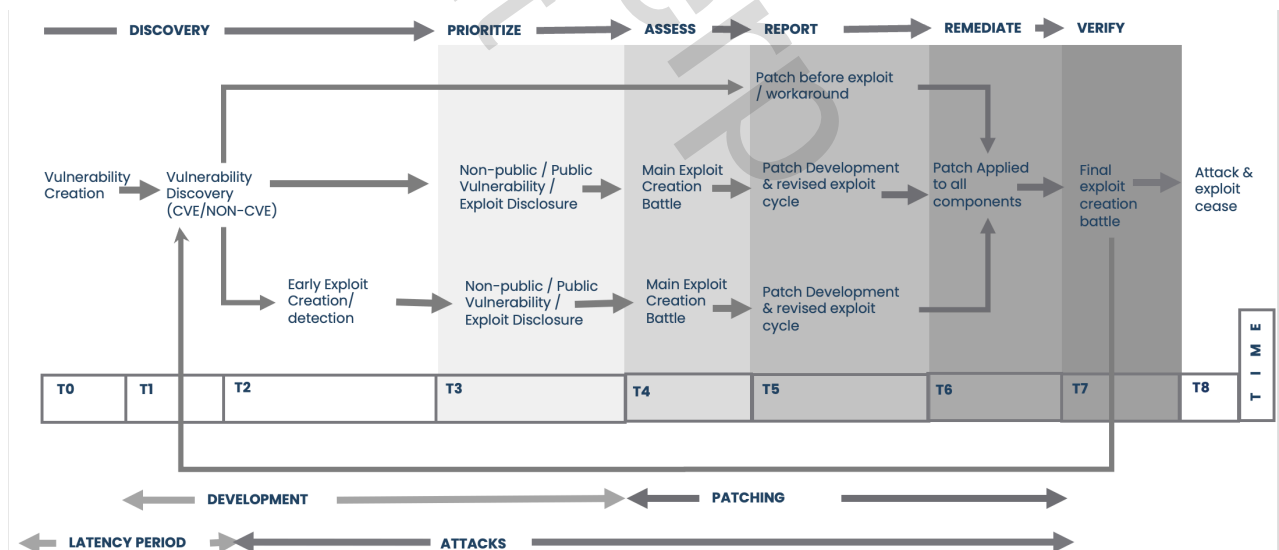
It is important to prepare for those events by developing an effective strategy for the management of vulnerabilities during the product life cycle, including regular monitoring, testing, risk assessment, prioritization, remediation, and verification, as well as communication, which are all essential activities to discover and fix new vulnerabilities and maintain cybersecurity coverage.

This vulnerability handling document refines the activities that are part of international standards such as [EN ISO/IEC 30111:2020 \[2\]](#), [EN ISO/IEC 29147:2020 \[3\]](#) and [ISO/IEC TR 5895:2022 \[4\]](#). It elevates, where appropriate, recommendations to mandatory requirements to ensure conformity with the Cyber Resilience Act (CRA) obligations. It integrates essential elements such as Software Bill of Materials (SBOM), regular testing and review activities, secure update mechanisms, and explicit requirements to support effective Coordinated Vulnerability Disclosure (CVD) and vulnerability-handling processes.

The rigor with which vulnerability handling activities are expected to be executed are expected to adhere to a risk-based approach, determined by the potential societal impact of a product's security failure. For example, the regular test and other monitoring activities are expected to be executed more frequently for products with higher criticality, and having a more detailed SBOM can improve the detection of vulnerabilities in components used by the product. The horizontal standards for the Cyber Resilience Act cannot be too prescriptive and thus require appropriate product risk-based criteria to be documented in the risk assessment and the cybersecurity plan for the product.

Identifying a product that can cause high-risk impact, which can be found across all categories covered by the Cyber Resilience Act, is integral to the regulatory risk assessment that needs to be conducted by the manufacturer. To support a risk-based approach, this document defines requirement enhancements.

[Figure 1](#) illustrates an example of the vulnerability life cycle model, where the period between vulnerability discovery and the application of security updates prolongs the window of opportunity for threat actors to exploit the vulnerability and to conduct a cybersecurity attack.



<sup>a</sup> Derived from *ENISA — STATE OF VULNERABILITIES 2018/2019 — Analysis of Events in the life of Vulnerabilities* ( December 2019 / Page 9 / Figure 2: Vulnerability life cycle )

**Figure 1 — Vulnerability life cycle**

**prEN 40000-1-3 (E)**

The vulnerability handling activities defined in this document are organized into the following distinct phases:

- **Preparation:** Establishing policies, processes, and capabilities for vulnerability intake and disclosure.
- **Receipt:** Receiving and monitoring vulnerability reports from internal and external sources.
- **Verification:** Assessing the validity, applicability, and severity of reported vulnerabilities.
- **Remediation:** Planning, developing, and testing fixes or mitigations.
- **Release:** Distributing security updates and publishing advisories.
- **Post-Release:** Monitoring effectiveness and applying lessons learned.

Manufacturers implementing this document will be equipped to demonstrate due diligence in vulnerability handling, maintain product security over time, and support transparency and trust across the digital ecosystem.

Ontwerp  
Draft

## 1 Scope

This document specifies the requirements and activities that focus on the process aspects of vulnerability handling applicable to manufacturers of products with digital elements (hereinafter referred to as "product").

The document is intended to support compliance with the Cyber Resilience Act (CRA) Regulation (EU) 2024/2847, particularly the essential requirements outlined in Annex I, Part II.

This document, with the appropriate requirement enhancements, is applicable across all product categories. Implementing these requirements enables a manufacturer to ensure security is maintained throughout the product life cycle.

## 2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

prEN 40000-1-1, *Cybersecurity requirements for products with digital elements - Vocabulary*

prEN 40000-1-2:2025, *Cybersecurity requirements for products with digital elements - Part 1-2: Principles for cyber resilience*

## 3 Terms and definitions

For the purposes of this document, the terms and definitions given in prEN 40000-1-1 and the following apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <http://www.iso.org/obp>
- IEC Electropedia: available at <http://www.electropedia.org/>

### 3.1

#### **test**

activity in which a system or component is executed under specified conditions, the results are observed or recorded, and an evaluation is made of some aspect of the system or component

Note 1 to entry: A test is carried out to measure or classify a characteristic or a property of an item by applying to the item a set of environmental and operating conditions and/or requirements.

[SOURCE: [ISO/IEC/IEEE 29119-2:2021 \[5\]](#), 3.21]

### 3.2

#### **review**

activity undertaken to determine the suitability, adequacy and effectiveness of the subject matter to achieve established objectives

[SOURCE: [ISO 31073:2022 \[6\]](#), 3.3.41]

**prEN 40000-1-3 (E)****3.3  
coordination**

set of activities including identifying and engaging stakeholders, mediating, communicating, and other planning in support of vulnerability disclosure

Note 1 to entry: The term “coordinated vulnerability disclosure” is used to denote a disclosure process that includes coordination.

[SOURCE: [EN ISO/IEC 29147:2020 \[3\]](#), 3.3]

**3.4  
upstream**

handling, processes and movements of goods that occur before the organization in the supply chain takes custody of the goods

[SOURCE: [ISO 28001:2007 \[7\]](#), 3.27]

**3.5  
downstream**

handling, processes and movements of goods when they no longer are in the custody of the organization in the supply chain

[SOURCE: [ISO 28001:2007 \[7\]](#), 3.10]

**4 General****4.1 Structure of this document**

Requirements in this document are assigned unique identifiers consisting of a three letter abbreviation for clause and for the requirement a two-letter abbreviation (“RQ” for a requirement, “RC” for a recommendation, and “PM” for a permission, all numbered independently, each starting at 01), followed by a number, separated by a hyphen.

This document supports the risk-based approach by providing requirement enhancements that are listed into the document with the acronym RE.

EXAMPLE 5.X.X [XXX-1] Title of the Section

....

5.X.X.X Requirement

....

[XXX-X-RQ-XX] Description of a requirement

[XXX-X-RQ-XX-RE] Description of a requirement enhancement

[XXX-X-RC-XX] Description of a recommendation

[XXX-X-PM-XX] Description of a permission

**4.2 Relationships with other international standards**

This document uses as building blocks the following standards and technical reports:

- [EN ISO/IEC 29147:2020 \[3\]](#) - Vulnerability disclosure - provides guidelines for manufacturers on how to process and remediate potential vulnerability reports reported by internal or external individuals or organizations. The major focus is on receiving reports about potential vulnerabilities and when distributing vulnerability remediation information to affected users.

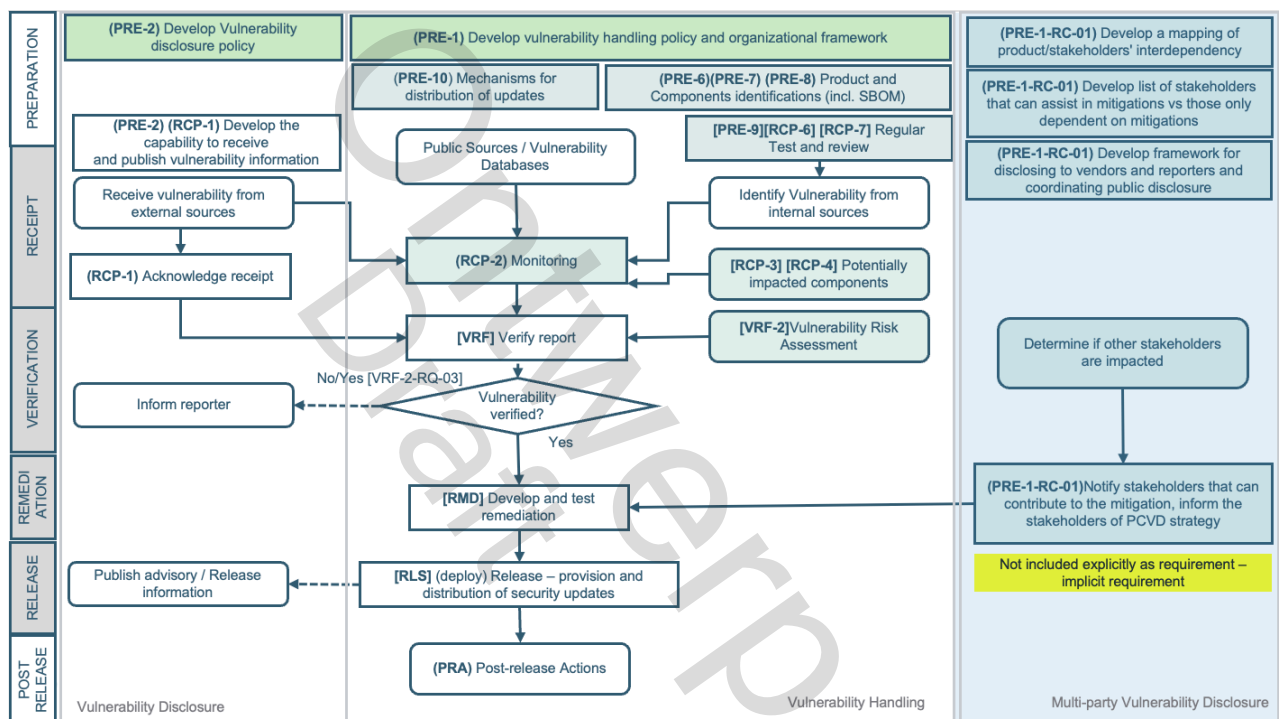
- [EN ISO/IEC 30111:2020 \[2\]](#) - Vulnerability handling processes - provides guidelines on how to investigate, process and resolve potential vulnerability reports.

To enhance the multi-party essence of the CVD and to capture the complexity of the supply chain and multiple stakeholder involved in the coordinated vulnerability disclosure process this document has been augmented with [ISO/IEC TR 5895:2022 \[4\]](#).

- [ISO/IEC TR 5895:2022 \[4\]](#) - Multi-party coordinated vulnerability disclosure and handling - clarifies and increases the application and implementation of [EN ISO/IEC 30111:2020 \[2\]](#) and [ISO/IEC 29147:2018 \[8\]](#) in multi-party coordinated vulnerability disclosure (MPCVD) settings.

NOTE [EN ISO/IEC 30111:2020 \[2\]](#) and [EN ISO/IEC 29147:2020 \[3\]](#) use the term “vendor” where CRA uses “manufacturer”.

The relationships between the referenced standards are shown in [Figure 2](#), which highlights the components that were introduced or substantially modified to align with the Cyber Resilience Act essential requirements.



<sup>a</sup> Derived from [ISO/IEC TR 5895:2022 \[4\]](#) — *Figure 2: The relationship between ISO/IEC 29147 and ISO/IEC 30111 with respect to MPCVD*

**Figure 2 — Relationships between referred standards and this document**

## 5 Vulnerability handling

### 5.1 General

This clause defines the key activities and requirements for vulnerability disclosure and handling, providing manufacturers with a structured foundation for designing and implementing their own processes. These processes enable manufacturers to manage communication among stakeholders, proactively discover and collect vulnerability information and reports, and diagnose and remediate vulnerabilities before they become public, thereby preventing malicious actors from exploiting them.

### 5.2 [APP] Applicability

## prEN 40000-1-3 (E)

### 5.2.1 General

The rigor applied to vulnerability handling activities follows a risk-based approach aligned with the product's risks.

### 5.2.2 [APP-1] Requirement enhancement applicability

#### 5.2.2.1 General

Manufacturers are normally responsible for conducting a risk assessment to assess the risks associated with the use of the product to determine the appropriate rigor for vulnerability handling.

Dependent upon the risks, there is an expectation to implement the relevant requirement enhancements in one or more of the following identified activities:

- [PRE-5-RQ-01-RE] Secure communication
- [PRE-7-RQ-03-RE] SBOM completeness
- [PRE-7-RQ-07-RE] SBOM software component hash
- [RLS-2-RQ-03-RE] Machine-readable advisories

NOTE **EDITORIAL NOTE:** CEN-CENELEC JTC13/WG9 invites feedback from the national organizations on the approach for requirement enhancements to better support the risk based approach.

#### 5.2.2.2 Input

- Product context ([prEN 40000-1-2 \[1\]](#), 6.2)
- Risk assessment ([prEN 40000-1-2 \[1\]](#), 6.4)

#### 5.2.2.3 Requirement

**[APP-1-RQ-01]** The applicability of the requirement enhancements shall be determined based on the product risks.

NOTE **Requirement Enhancement:** Requirements marked with "RE" indicate risk-based enhancements that apply where the regulatory risk assessment determines that additional rigor is necessary.

#### 5.2.2.4 Output

- Statement of applicability

#### 5.2.2.5 Assessment criteria

- Evaluation of the applicability criteria based on the product context and risk assessment

## 5.3 [PRE] Preparation

### 5.3.1 General

The preparation phase lays the foundation for establishing appropriate vulnerability handling and disclosure processes and policies to support the subsequent phases, providing a structured, methodological approach to identify, verify, and address vulnerabilities, including communication. This phase also includes requirements such as identifying software and hardware components, focusing on creating the Software Bill of Materials (SBOM), and establishing a coordinated vulnerability disclosure and vulnerability handling policy.

### 5.3.2 [PRE-1] Policy on vulnerability handling

### 5.3.2.1 General

A manufacturer establishes and maintains an internal vulnerability handling policy to clearly define their approach for investigating and remediating security vulnerabilities. An additional important aspect covered is the testing strategy that should be defined to support effective and regular tests and reviews of its products. This policy forms a core part of the manufacturer's overall vulnerability handling process and is compatible with the external coordinated vulnerability disclosure policy as per [5.3.3](#). The intended audience for the vulnerability handling policy is the internal staff.

### 5.3.2.2 Input

- Coordinated Vulnerability Disclosure policy
- [5.3.10](#)
- Software bill of materials

### 5.3.2.3 Requirement

**[PRE-1-RQ-01]** A policy on vulnerability handling shall be created, put in place and adhered to.

NOTE 1 For additional guidance on the vulnerability handling policy, refer to [EN ISO/IEC 30111:2020 \[2\]](#), 6.3.

**[PRE-1-RC-01]** An organizational framework should be created to support the activities defined in the vulnerability handling process as per *[PRE-1-RQ-01]*.

NOTE 2 For additional guidance on organizational framework, refer to [EN ISO/IEC 30111:2020 \[2\]](#), 6.4.

**[PRE-1-RQ-02]** The vulnerability handling policy shall include:

- basic guidance, principles, and responsibilities for handling potential vulnerabilities in products
- measures to prevent premature disclosure of information about potential vulnerabilities before they are fixed
- a target schedule for remediation development

NOTE 3 The target schedule serves as a guide for completing the activities of remediation development, as described in [5.6](#).

NOTE 4 The target schedule depends on different aspects such as the complexity of the remediation to be developed, and the potential risk of the vulnerability, as assessed in [5.5.2](#). Additional variables include the complexity of the interactions with the supply chain and entities involved in the investigation and remediation activities.

- strategies related to the regular [test \(3.1\)](#) and [review \(3.2\)](#) activities, as defined in [5.3.10](#).

**[PRE-1-RC-02]** A policy on vulnerability handling should include:

- the full process description that is aligned with the expectations of this document
- the roles and responsibilities that will be assigned to handle the potential vulnerabilities in the product

NOTE 5 For additional guidance on role and responsibilities including definition of usual activities refer to [EN ISO/IEC 30111:2020 \[2\]](#):

- *6.5 Vendor CSIRT or PSIRT*
- *6.6 Responsibilities of the product business division*
- *6.7 Responsibilities of customer support and public relations*

**prEN 40000-1-3 (E)**

- *6.8 Legal consultation*
- measures to prevent premature disclosure of information about potential vulnerabilities before they are fixed, as defined in [5.3.6](#)
- activities and criteria to define a target schedule for the remediation of the vulnerability, which depends on the embargo period, established and influenced by the complexity of the case by case situation with impacted upstream stakeholders, and on the criticality of the vulnerability and the product itself
- where known and appropriate, it is important to list the downstream stakeholders that are using the product under scope

NOTE 6 Appropriateness depends on privacy and confidentiality agreements with downstream stakeholders.

- the mapping of upstream stakeholders to support the component identification required by [5.3.8](#) and [5.3.9](#)

NOTE 7 For additional guidance on roles and responsibilities in a multi-party configuration that includes definition of usual activities, refer to [ISO/IEC TR 5895:2022 \[4\]](#), Clause 8.

**[PRE-1-RQ-03]** The effectiveness of the vulnerability handling process shall be monitored.

NOTE 8 For additional guidance on ways to monitor the effectiveness of the vulnerability handling process, refer to [EN ISO/IEC 30111:2020 \[2\]](#), 7.2.

**[PRE-1-RQ-04]** For a timely resolution of the issues, a mapping of upstream interdependencies, including open source, is required to support the coordination and notification activities when a vulnerability is discovered.

**[PRE-1-RQ-05]** A policy on vulnerability handling shall support all the activities that are defined in the vulnerability disclosure policy, as described in [5.3.3](#).

#### **5.3.2.4 Output**

- Policy on vulnerability handling
- List of the upstream stakeholders
- Data collection on target with the schedule remediation activities

#### **5.3.2.5 Assessment criteria**

- Policy on vulnerability handling that covers the activities defined within this document
- Existence of a list of upstream stakeholders linked to the components integrated into the product with a completeness check using the SBOM
- Policy on vulnerability handling that includes:
  - appropriate alignment with the coordinated vulnerability disclosure
  - demonstrated organizational capabilities, roles and responsibilities to deal timely and in a systematic way in the event of a vulnerability
- Appropriate testing and review policies defined including regularity and timeline of those activities as aligned with [5.3.10](#)
- Evidence of process monitoring for vulnerability handling effectiveness

#### **5.3.3 [PRE-2] Policy on coordinated vulnerability disclosure**

### 5.3.3.1 General

The purpose of the coordinated vulnerability disclosure policy is to communicate the manufacturer's intentions, responsibilities, and expectations regarding vulnerability disclosure. A coordinated vulnerability disclosure policy encompasses both two-party coordination (e.g. between the reporter and the manufacturer) and multi-party disclosure involving multiple stakeholders. To support this, the manufacturer develops and publishes an external coordinated vulnerability disclosure policy and ensures the related internal activities are in place to effectively coordinate the disclosure of vulnerabilities.

In addition, to prevent attackers from gaining early access to sensitive information, reporters typically notify manufacturers privately, and refrain from public disclosure until a fix is available after an agreed-upon embargo period has passed. The receipt, verification, and remediation development stages are generally conducted within this embargo period, ensuring that vulnerabilities are addressed securely and responsibly by all the parties involved in the process.

### 5.3.3.2 Input

- Vulnerability handling policy

### 5.3.3.3 Requirement

**[PRE-2-RQ-01]** A policy on coordinated vulnerability disclosure (CVD) shall be created, published in an accessible format and adhered to.

NOTE 1 Accessibility requirements and advice can be found in [EN 301 549 v3.2.1 \[9\]](#).

**[PRE-2-RQ-02]** A coordinated vulnerability disclosure policy shall include one or more contact mechanisms.

NOTE 2 Contact information can be available for both reporting vulnerabilities and for requesting additional information about the coordinated vulnerability program.

For additional guidance on policy elements refer to [EN ISO/IEC 29147:2020 \[3\]](#), 9.2.2.

A list of possible contact mechanisms includes, but is not limited to:

- e-mail address;
- phone number;
- web form;
- contact information for customer service.

**[PRE-2-RC-01]** The contact mechanisms should provide accessibility via more than one sensory channel.

EXAMPLE The purpose of providing more than one sensory channel is to address situations in which a potential user with a writing impediment can still, for example, call a phone number to ask for and provide information.

NOTE 3 Accessibility requirements and advice can be found in [EN 301 549 v3.2.1 \[9\]](#).

**[PRE-2-RQ-03]** Setting expectations for on-going communication shall be stated in this policy.

NOTE 4 The reference for this requirement is [5.3.5](#).

**[PRE-2-RC-02]** A vulnerability disclosure policy should include following elements:

- vulnerability report contents;
- secure communication options as detailed in [5.3.6](#);
- scope;

**prEN 40000-1-3 (E)**

- publication;
- recognition.

NOTE 5 For additional guidance on recommended policy elements refer to [EN ISO/IEC 29147:2020 \[3\]](#), 9.3.

**[PRE-2-RC-03]** A disclosure strategy should be in place to ensure that the information on vulnerability is not disclosed before it is addressed.

NOTE 6 For additional guidance on the embargo period refer to [EN ISO/IEC 29147:2020 \[3\]](#), 5.6.8.

For additional guidance on the disclosure strategy refer to [ISO/IEC TR 5895:2022 \[4\]](#), 7.3.2.

NOTE 7 Vulnerability disclosure requires flexibility; there is no one-size-fits-all approach. Reports, timelines, and responses can be tailored to each case and agreed upon by all stakeholders.

NOTE 8 Different embargo periods (vulnerability-by-vulnerability) can be negotiable between manufacturers and reporters, or a coordinator if involved.

**5.3.3.4 Output**

- Policy on coordinated vulnerability disclosure

**5.3.3.5 Assessment criteria**

- Evidence of the policy on coordinated vulnerability disclosure that is published and followed, and aligned with the internal vulnerability handling policy to support its implementation
- Evidence of the policy on coordinated vulnerability disclosure that include agreements or definition of parameters necessary to estimate the embargo period during the receipt phase
- Evidence that the contact mechanisms have been published in an accessible format and consider more than one sensory channel

**5.3.4 [PRE-3] Operational security****5.3.4.1 General**

Information related to vulnerabilities is generally sensitive information, as vulnerabilities can be used by malicious actors. All external communication, as well as the manufacturers' internal processes, need to take operational security into account. The confidentiality controls can be lifted after remediation and advisory information has been published. Depending on the organization and its products, confidentiality controls can be as simple as marking information with TLP (Traffic Light Protocol) or be supported by technical controls like access control.

**5.3.4.2 Input**

- Policy on vulnerability handling
- Policy on coordinated vulnerability disclosure

**5.3.4.3 Requirement**

**[PRE-3-RC-01]** Operational security should be provided throughout the activities of receiving ([5.4.2](#)) and communicating about ([5.3.5](#)) vulnerability information or reports.

NOTE 1 For additional guidance related to this requirement, refer to [EN ISO/IEC 29147:2020 \[3\]](#), 6.7.

NOTE 2 Operational security can be implemented in a way that maintains accessibility for submitting vulnerability reports, including the availability of an anonymous reporting mechanism.

**[PRE-3-RQ-01]** Limiting access to non-public vulnerability information on a need-to-know basis shall be considered.

NOTE 3 For additional guidance related to this requirement, refer to [EN ISO/IEC 30111:2020 \[2\]](#), 7.3.

#### 5.3.4.4 Output

- Documented security measures applied during vulnerability handling
- Documented security measures applied during coordinated vulnerability disclosure
- Evidence of the implementation of the capability to receive the reports

#### 5.3.4.5 Assessment Criteria

- Evidence of documented security measures

### 5.3.5 [PRE-4] On-going communication

#### 5.3.5.1 General

The purpose of this phase is to maintain regular communication channels during the vulnerability handling activities with relevant stakeholders, such as users, coordinators, reporters, manufacturers, open-source stewards, maintainers of non-commercial open-source projects and other stakeholders, where required. Communication can be aligned with the product's life cycle and occur in parallel with all vulnerability handling phases, rather than following a strict sequence.

#### 5.3.5.2 Input

- policy on coordinated vulnerability disclosure

Depending on the phase of vulnerability handling, not all of these may be required or available:

- Vulnerability report from internal or external source, see section [5.4.3](#)
- Verified vulnerability report including an initial assessment of the vulnerability and its severity, as required per [5.5.2](#)
- Results of the risk assessment, as required per [5.5.3](#)
- Remediation plan, as required per [5.6.2](#)
- Remediation and/or fix, as required per [5.6.3](#)
- Timeline

#### 5.3.5.3 Requirement

**[PRE-4-RQ-01]** Communication with reporters and other stakeholders shall be established and maintained.

NOTE 1 For additional guidance on communication with reporters and other stakeholder, refer to [EN ISO/IEC 29147:2020 \[3\]](#), 6.5.

**[PRE-4-RQ-02]** Communication with users shall implement accessible modes of communication.

NOTE 2 For additional guidance on accessible communication methods refer to [prEN 40000-1-2 \[1\]](#), 6.6.

#### 5.3.5.4 Output

- Record of the communication with users and other relevant stakeholders

#### 5.3.5.5 Assessment criteria

- Presence in the CVD policy on commitments related to on-going communications

**prEN 40000-1-3 (E)**

- Presence of accessible modes of communication
- If reports have been submitted, evidence exists that communication with stakeholders has been performed

**5.3.6 [PRE-5] Secure communication****5.3.6.1 General**

The purpose of this subclause is to define secure communication mechanisms. Since vulnerability information can be exploited to attack affected systems, it is essential that such sensitive information, especially when not publicly disclosed, is communicated confidentially.

**5.3.6.2 Input**

- Reporting mechanism, as required per [5.4.2](#).

**5.3.6.3 Requirement**

**[PRE-5-RC-01]** Secure communication mechanisms should be provided throughout the activities of receiving and communicating vulnerability information or reports.

**[PRE-5-RQ-01-RE]** Secure communication mechanisms shall be provided and communicated to support [5.4.2](#) can.

NOTE 1 Initial contact (reporter-controlled). Because initial contact can arrive via any channel (e.g. email, social media, phone), the organization accepts the report, registers it, and offers to continue over one of the secure options when sensitive details (exploits, customer data, keys, configuration data) are required.

NOTE 2 Providing a means of secure communication is essential, but is not enforced if the reporter is unwilling or unable to support it.

**[PRE-5-RC-02]** Secure communication methods should support confidentiality and message integrity.

**EXAMPLE**

- web-based forms or applications using TLS (HTTPS)
- e-mail encryption and signing using S/MIME or OpenPGP

NOTE 3 For additional guidance on secure communication, refer to [EN ISO/IEC 29147:2020 \[3\]](#), 5.8.

**[PRE-5-RC-03]** Stakeholders should have a way to report vulnerabilities anonymously.

**[PRE-5-RC-04]** Methods of secure communication should not disrupt the accessibility of external communication.

**5.3.6.4 Output**

- Documentation on the secure communication mechanism used
- Evidence of secure communication

**5.3.6.5 Assessment criteria**

- Presence in the CVD policy on commitments related to mechanisms of secure communication
- If reports have been submitted, evidence exists that secure communication with stakeholders has been performed

### 5.3.7 [PRE-6] Product identification

#### 5.3.7.1 General

This subclause describes the activities of recording relevant information to enable the product to be identifiable, for different purposes such as vulnerability handling, software bill of material generation and verification, and vulnerability information sharing and reporting.

#### 5.3.7.2 Input

- Rules on naming and versioning conventions

#### 5.3.7.3 Requirement

**[PRE-6-RQ-01]** A product shall be identifiable by providing at least the following information:

- manufacturer name;
- product name;
- (for hardware): any hardware product identifier, if applicable;
- (for software): any software product identifier, if applicable.

**[PRE-6-RQ-02]** If the product consists of both hardware and software, information for product identification, as per *[PRE-6-RQ-01]*, shall be provided separately.

NOTE A taxonomy of methods for identifying the product is documented in [prEN IEC 61360-7:2025 \[10\]](#). The resource can be found online with reference *0112/2///61360\_7#AAS005#001* at the following web address [https://cdd.iec.ch/cdd/iec61360-7/iec61360-7.nsf/classes/0112-2---61360\\_7%23AAS005](https://cdd.iec.ch/cdd/iec61360-7/iec61360-7.nsf/classes/0112-2---61360_7%23AAS005)

EXAMPLE Information for product identification can be provided using one or more of the following:

(for hardware)

- part number
- serial number
- batch number
- firmware version
- production date

(for software)

- software version
- release version
- build number
- software Hash Identifier (SWHID)
- release date

#### 5.3.7.4 Output

- Record of information for product identification

#### 5.3.7.5 Assessment criteria

- Evidence of product identification

**prEN 40000-1-3 (E)****5.3.8 [PRE-7] Identification of software components****5.3.8.1 General**

This subclause describes the activities of identifying the software components that make up the product. The purpose of this identification is to enable effective vulnerability handling by ensuring that all components are known, traceable, and can be assessed for potential cybersecurity risks.

**5.3.8.2 Input**

- Binary artefacts
- Configuration files
- Source code
- Cybersecurity architecture and design documents ([prEN 40000-1-2 \[1\]](#), 7.4)
- [5.3.7](#)
- Risk assessment ([prEN 40000-1-2 \[1\]](#), 6.4)

**5.3.8.3 Requirement**

**[PRE-7-RQ-01]** All software components contained in the product shall be identified and documented.

**[PRE-7-RQ-02]** For each component identified in [PRE-7-RQ-01], the following information shall be included:

- Software producer

NOTE 1 For open-source software, which is supported by an open-source steward, this is the name of the stewarding organization.

- Component name
- Component version

**[PRE-7-RQ-03]** An SBOM shall be drawn up, including at least the top-level dependencies that are contained in the product, as identified in [PRE-7-RQ-01].

NOTE 2 For additional guidance on top-level dependencies, refer to BSI TR-03183-2 [\[11\]](#), 8.3.1.

**[PRE-7-RQ-03-RE]** All the software components identified in [PRE-7-RQ-01] shall be drawn up in the SBOM to detect transitive dependencies when technically feasible.

NOTE 3 It might not always be possible to obtain the necessary information from suppliers to generate an SBOM that includes all transitive dependencies.

NOTE 4 For additional guidance on the depth and extent of the SBOM refer to [ISO/IEC 27036-3:2023 \[12\]](#), B.3.1.3.

NOTE 5 A more granular SBOM can better support the ability to faster and more efficiently detect vulnerabilities in the components that are part of the product.

**[PRE-7-RQ-04]** The SBOM shall be assembled in a structured, machine-readable format.

NOTE 6 The SBOM includes the relationship of the identified software components. This includes the software components on which this software component is directly dependent, or which this software component contains.

NOTE 7 Some of the widely used machine-readable formats by software ecosystem stakeholders to generate and consume SBOMs are, for example:

- Software Package Data eXchange (SPDX) ([ISO/IEC 5962:2021 \[13\]](#))
- CycloneDX

**[PRE-7-RQ-05]** If the software component is updated with a new build or release, a new SBOM shall be created to reflect the new version of the software.

NOTE 8 This includes software builds to integrate an updated component or dependency.

**[PRE-7-RC-01]** When new details about the identified components are detected or the need to correct an error in the existing SBOM is discovered, a revised SBOM should be issued.

**[PRE-7-RQ-06]** Metadata for the SBOM shall include:

- SBOM Author

NOTE 9 The name of the entity that creates the SBOM data for a component.

- Version
- Timestamp

NOTE 10 Timestamp is used to record the date and time of the SBOM creation and modification by the Author. For additional guidance on the timestamp format, refer to [ISO 8601-1:2019 \[14\]](#) (e.g. 2024-05-23T13:51:37Z).

**[PRE-7-RQ-07]** For each component part of SBOM as [PRE-7-RQ-02], the following information shall be included:

- Information as required from [PRE-7-RQ-02]
- Dependency relationship
- Unique component identifiers

NOTE 11 Identifier(s) used to identify a component or serve as a look-up key for relevant databases.

EXAMPLE The component identifier can be *Common Platform Enumeration (CPE)*, *Package URL (PURL)*, or *SoftWare Hash IDentifier (SWHID)*. If more than one component identifier is available, all of them can be stated.

NOTE 12 SBOM information can additionally include:

- *Licence information of the component*

**[PRE-7-RQ-07-RE]** If the supplier provides the hash and the corresponding algorithm for the component, it shall be included in the SBOM.

NOTE 13 The original component artefact mentioned in the enhanced requirement refers to the original hash provided by the component provider.

NOTE 14 Source code hashes identify the upstream components from which the product is built, so that vulnerabilities that might be inherited can be identified. The shipped digital element can also have its own hash.

NOTE 15 In certain development models, such as those involving the integration of individual code snippets from open-source projects, it is not possible to include the hash and the corresponding algorithm in the SBOM, as no complete artefact from the original component exists.

#### 5.3.8.4 Output

- Identified software components
- Software Bill of Materials (SBOM)

#### 5.3.8.5 Assessment criteria

- Evidence of the SBOM in a structured machine-readable format

**prEN 40000-1-3 (E)**

- Comparison of identified assets to SBOM entries to demonstrate appropriate completeness based on the risk assessment and the readiness of the organization

**5.3.9 [PRE-8] Identification of hardware components****5.3.9.1 General**

This clause describes the activities for identifying the hardware components used in the product that may affect its cybersecurity. The purpose of this identification is to enable effective vulnerability handling by ensuring that the relevant hardware components integrated into the product are known, traceable, and assessable for potential cybersecurity risks.

**5.3.9.2 Input**

- Cybersecurity architecture and design ([prEN 40000-1-2 \[1\]](#), 7.4)
- Risk assessment ([prEN 40000-1-2 \[1\]](#), 6.4)

**5.3.9.3 Requirement**

**[PRE-8-RQ-01]** Hardware components that are integrated in the product shall be identified and documented.

NOTE 1 For the specific definition of 'hardware', refer to [Clause 3](#).

**[PRE-8-RQ-02]** For each identified hardware component as per [PRE-8-RQ-01], the following information shall be recorded:

- hardware producer;
- component name;
- component identifier;
- if applicable, firmware version.

NOTE 2 A taxonomy of methods for identifying the product is documented in [prEN IEC 61360-7:2025 \[10\]](#). The resource can be found online with reference *0112/2///61360\_7#AAS005#001* at the following web address [https://cdd.iec.ch/cdd/iec61360-7/iec61360-7.nsf/classes/0112-2---61360\\_7%23AAS005](https://cdd.iec.ch/cdd/iec61360-7/iec61360-7.nsf/classes/0112-2---61360_7%23AAS005)

NOTE 3 Further available information can be recorded, such as:

- part number;
- serial number;
- batch number;
- component version;
- production date;
- hardware revision.

**5.3.9.4 Output**

- List of hardware components and related information recorded

**5.3.9.5 Assessment criteria**

- Evidence of the list of identified hardware components and related information

- Comparison of identified assets to the list of hardware components entries to demonstrate appropriate completeness based on the risk assessment

### 5.3.10 [PRE-9] Planning regular test and reviews

#### 5.3.10.1 General

Regular testing and review are necessary to maintain a product's security. Depending on the risks associated with the product's use, specific activities such as regular vulnerability scanning and other testing and review should be planned. This plan, including the schedule and actions, is needed for the security maintenance of a product, taking into account the product's context.

#### 5.3.10.2 Input

- Product context ([prEN 40000-1-2 \[1\]](#), 6.2)
- Cybersecurity architecture and design ([prEN 40000-1-2 \[1\]](#), 7.4)
- Product cybersecurity requirements ([prEN 40000-1-2 \[1\]](#), 7.3)
- Risk assessment ([prEN 40000-1-2 \[1\]](#), 6.4)
- Product cybersecurity verification and validation including test cases and methodologies ([prEN 40000-1-2 \[1\]](#), 7.6)

#### 5.3.10.3 Requirement

**[PRE-9-RQ-01]** A risk-based security test and review plan shall be created. The plan shall include schedules and frequency of specific tests and reviews, and be appropriate to the assessed risks of the use of the product.

NOTE 1 For additional guidance on security test and review activities, refer to [prEN 40000-1-2 \[1\]](#), 7.6.

NOTE 2 A plan can be designed for an individual product, a product class or a product portfolio.

NOTE 3 The regularity of test and review activities is impacted by product life cycle considerations, changes in the risk level and the threat landscape, and incidents.

**[PRE-9-RQ-02]** A security test and review plan shall consider at least the following aspects:

- product context;
- cybersecurity architecture and design;
- product cybersecurity requirements;
- risk assessment;
- test cases and test methodologies.

NOTE 4 Security testing considers updates in technology and knowledge of vulnerabilities and threats.

**[PRE-9-RQ-03]** Security reviews shall consider at least the following sources:

- standards and publications describing the state-of-the-art in cybersecurity;
- changes in the threat landscape applicable to the product;
- vulnerabilities found in the product and its components;
- vulnerabilities found in similar products and their components; or

**prEN 40000-1-3 (E)**

- information about the practical conditions of use as obtained by customer feedback, for example, due to support cases.

**[PRE-9-RQ-04]** A security test and review plan shall be maintained based on the results of performed tests and reviews.

**5.3.10.4 Output**

- Security test and review plan, including, if applicable, its updates

**5.3.10.5 Assessment criteria**

- Evidence of the existence of the security test and review plan
- Evidence of the elements of the security test and review plan being performed as planned

**5.3.11 [PRE-10] Mechanisms for distribution****5.3.11.1 General**

This subclause clarifies the preparation steps that enable the manufacturer to provide information and distribute security updates. The update mechanisms can include both manual and/or (semi-)automatic updates.

These mechanisms include, for example, websites for publishing information and the infrastructure required to enable automatic security update distribution.

**5.3.11.2 Input**

- Product update mechanisms supported and related documentation

**5.3.11.3 Requirement**

**[PRE-10-RQ-01]** A mechanism shall be provided to distribute security updates in a secure manner in accordance with prEN 40000-1-2:2025, 7.7.2.

**[PRE-10-RQ-02]** A mechanism for the distribution of security information for the product shall be provided.

**NOTE** This includes mechanisms for providing advisories, release notes, installation information, and notifications.

**[PRE-10-RQ-03]** Where applicable, mechanisms for automatic distribution of security updates for product shall be provided.

**5.3.11.4 Output**

- Documentation on the distribution mechanisms for information and security updates.

**5.3.11.5 Assessment criteria**

- Evidence of capability to distribute updates and information in a secure manner.

**5.4 [RCP] Receipt****5.4.1 General**

The receipt phase outlines requirements for monitoring both internal and external sources, as well as for receiving vulnerability reports, including those derived from testing and monitoring, submitted by various stakeholders.

In this phase, the manufacturer actively monitors publicly available sources for vulnerability disclosures or information that may affect its products. Upon receiving relevant vulnerability reports or information, the data are compared against the SBOM and the list of hardware components integrated in the product. By cross-referencing these sources, the manufacturer can efficiently identify any potentially affected components or products.

This phase also covers the initial assessment activities needed to identify potentially affected components. Essential to this includes activities related to regular tests and internal reviews to proactively discover new vulnerabilities.

## 5.4.2 [RCP-1] Capability to receive reports

### 5.4.2.1 General

The purpose of establishing the capability to receive vulnerability reports and related information is to provide researchers, users, and other interested stakeholders with mechanisms for timely reporting that are available and accessible. Publicly available reporting interfaces considering different sensory channels are essential to facilitate the prompt sharing of vulnerability information.

### 5.4.2.2 Input

- Policy on coordinated vulnerability disclosure

### 5.4.2.3 Requirement

**[RCP-1-RQ-01]** A publicly accessible reporting mechanism facilitating accessible modes as per [5.3.3.3 PRE-2-RC-01](#) shall be provided to enable the receipt of vulnerability information or reports.

NOTE 1 For additional guidance on mechanisms for receiving vulnerability information or reports, refer to [EN ISO/IEC 29147:2020 \[3\]](#), 6.2.2, which includes:

- web-based submission forms;
- bug or issue tracking systems;
- dedicated vulnerability reporting services;
- email addresses—preferably aliases, mailing lists, or role-based accounts that are not tied to a specific individual;
- phone number or similar.

An additional consideration can be to include also a security.txt file in accordance with [RFC 9116:2022 \[15\]](#)

NOTE 2 For additional guidance on accessibility requirements, refer to [EN 301 549 v3.2.1 \[9\]](#), which is already part of the accessibility consideration present in [prEN 40000-1-2 \[1\]](#).

**[RCP-1-RQ-02]** A mechanism shall be in place to track reported vulnerabilities with the use of an identifier or tracking number.

NOTE 3 For additional guidance on mechanisms for receiving vulnerability information or reports, refer to [EN ISO/IEC 29147:2020 \[3\]](#), 6.2.4.

The support for an identifier, label, or tracking system would enable easy traceability of the report during on-going communications with stakeholders within the scope of vulnerability handling and disclosure activities.

**[RCP-1-RQ-03]** A receipt of a potential vulnerability report shall be acknowledged within a time frame that is established and declared based on the coordinated vulnerability disclosure policy.

NOTE 4 For additional guidance on mechanisms for acknowledgement of received vulnerability information or reports, refer to [EN ISO/IEC 29147:2020 \[3\]](#), 6.2.5.

**[RCP-1-RC-01]** Reports should be accepted even if they use less secure mechanisms as provided by [5.3.6](#).

**prEN 40000-1-3 (E)****5.4.2.4 Output**

- Publicly available reporting mechanisms in accessible formats and accessible modes of communication
- One or multiple documented reporting mechanisms
- If a vulnerability was reported, it is expected to have evidence of the received report with the assigned tracking number or identifier

NOTE Reception of a confirmation demonstrates successful two-way communication

**5.4.2.5 Assessment criteria**

- Evidence of a publicly available reporting mechanism that is accessible
- Evidence of stored reports and the assigned tracking identifier, if a vulnerability was reported

**5.4.3 [RCP-2] Monitoring****5.4.3.1 General**

This subclause outlines the monitoring activities for gathering vulnerability information. It involves tracking public sources and receiving information from private sources to identify potential vulnerabilities that could impact the product.

**5.4.3.2 Input**

- Internal and external sources for vulnerability information

**5.4.3.3 Requirement**

**[RCP-2-RQ-01]** Vulnerability information or reports from internal and external sources shall be monitored.

NOTE 1 It is preferable to have automation in place for monitoring activities.

**[RCP-2-RQ-02]** The minimum list of sources that shall be used is:

**External sources**

- EU Vulnerability Database
- Reported vulnerabilities ([5.4.2](#))

**Internal sources**

- Regular testing [5.4.7](#)
- Regular review [5.4.8](#)

**[RCP-2-RQ-04]** The list of third-party components shall be monitored for end of support and usage.

NOTE 2 For open-source projects without an end-of-support date, this is typically determined by assessing whether the project is still actively maintained.

**5.4.3.4 Output**

- Record of relevant vulnerability information
- List of the selected internal and external sources monitored

#### 5.4.3.5 Assessment criteria

- Evidence of a list of internal and external sources monitored
- Evidence of pertinent vulnerability record information

### 5.4.4 [RCP-3] Potentially impacted software components

#### 5.4.4.1 General

This clause describes the activities for comparing the product's identified software components with incoming vulnerability information. Optionally, it is possible to automate this using the SBOM.

#### 5.4.4.2 Input

- Vulnerability information from [5.4.3](#)
- List of identified software components [5.3.8](#)
- Software Bill of Materials from [5.3.8](#)

#### 5.4.4.3 Requirement

**[RCP-3-RQ-01]** Potentially affected software components shall be identified based on vulnerability information collected from [5.4.3](#).

NOTE Automation is possible considering the SBOM.

#### 5.4.4.4 Output

- List of potentially impacted software components with related vulnerability information

#### 5.4.4.5 Assessment criteria

- Evidence that identification activities have been performed
- Evidence of the identified potential vulnerabilities in the software components, if applicable.

### 5.4.5 [RCP-4] Potentially impacted hardware components

#### 5.4.5.1 General

This subclause describes the activities for comparing the product's hardware component list with received vulnerability reports to identify potentially impacted hardware components.

#### 5.4.5.2 Input

- Vulnerability information from [5.4.3](#)
- List of identified hardware components [5.3.9](#)

#### 5.4.5.3 Requirement

**[RCP-4-RQ-01]** Potentially affected hardware components shall be identified based on vulnerability information collected from [5.4.3](#).

#### 5.4.5.4 Output

- List of potentially impacted hardware components with related vulnerability information

**prEN 40000-1-3 (E)****5.4.5.5 Assessment criteria**

- Evidence that identification activities have been performed
- Evidence of the identified potential vulnerabilities in the hardware components, if applicable.

**5.4.6 [RCP-5] Coordinator involvement****5.4.6.1 General**

The purpose of this phase is to support transparent, timely communication by actively engaging with a coordinator. While optional, a coordinator is especially helpful when vulnerabilities affect multiple manufacturers or when direct communication between the stakeholders is complex or not feasible.

**5.4.6.2 Input**

- Coordinated vulnerability handling policy
- Coordinated vulnerability disclosure policy

**5.4.6.3 Requirement**

**[RCP-5-RC-01]** A coordinator should be assigned and involved in the vulnerability handling process, where appropriate.

NOTE For additional guidance on coordinator involvement, refer to [EN ISO/IEC 29147:2020 \[3\]](#), 5.5.5 and 6.6, and for the coordinator role definition refer to [EN ISO/IEC 29147:2020 \[3\]](#), Clause 8.

**5.4.6.4 Output**

- Assigned coordinator role, where appropriate

**5.4.6.5 Assessment criteria**

- Where appropriate, evidence that a coordinator was assigned and involved during the vulnerability handling process

**5.4.7 [RCP-6] Performing regular tests****5.4.7.1 General**

Regular testing helps maintain the security posture. Some testing methods are described in [prEN 40000-1-2:2025 \[16\]](#), 7.6. The selection of appropriate tests and their schedules are dependent upon the product risk-based criteria related to the potential negative impact of vulnerabilities on the product's security posture over time, as documented in [5.3.10](#).

**5.4.7.2 Input**

- Security test and review plan ([5.3.10](#))
- Cybersecurity verification and validation as defined by [prEN 40000-1-2:2025 \[16\]](#), 7.6

**5.4.7.3 Requirement**

**[RCP-6-RQ-01]** Security testing shall be performed according to the security test and review plan.

NOTE For additional guidance on regular security testing refer to [prEN 40000-1-2:2025 \[16\]](#), 7.6.

**5.4.7.4 Output**

- Security test results

#### 5.4.7.5 Assessment criteria

- Evidence of security tests being performed as planned
- Evidence of security test results

#### 5.4.8 [RCP-7] Performing regular reviews

##### 5.4.8.1 General

Maintaining a product's security is an ongoing task. This includes performing security tests throughout the product's support period. It also includes activities to reassess the threats and risks posed to the product due to changes in cybersecurity attack techniques or the way the product is used in practical conditions.

The needs regarding these regular tests and reviews depend on the type of product and its use. A simple product developed on demand for a specific customer and purpose, as an individual unit, might require very few actions, while a more complex product supplied in large quantities for exposure to the Internet might require stringent monitoring.

The security risk a product is exposed to is not static. It changes as attack methods or the threat landscape evolves. This can, for example, include knowledge of cryptographic algorithms' strengths.

It can also turn out that the product context is not correctly described. For example, the product's use or operational environment may differ from the description during practical use.

##### 5.4.8.2 Input

- Security test and review plan
- Product context ([prEN 40000-1-2:2025 \[16\]](#), 6.2 )
- Cybersecurity architecture and design ([prEN 40000-1-2:2025 \[16\]](#), 7.4)
- Information and updates about threat landscapes and the state-of-the-art in cybersecurity
- Information about cybersecurity issues found in the product
- Information about practical conditions of use of the product
- Risk assessment ([prEN 40000-1-2:2025 \[16\]](#), 6.4)

##### 5.4.8.3 Requirement

**[RCP-7-RQ-01]** Security reviews shall be performed according to the security test and review plan.

NOTE 1 For additional guidance on regular security reviews, refer to [prEN 40000-1-2:2025 \[16\]](#), 6.7.

**[RCP-7-RQ-02]** The assumptions and all inputs of the product cybersecurity risk assessment shall be reviewed periodically (at least once a year), even if the product design does not change.

NOTE 2 For additional guidance on regular review, refer to:

- [prEN 40000-1-2:2025 \[16\]](#), 6.7
- [prEN 40000-1-2:2025 \[16\]](#), 7.2

##### 5.4.8.4 Output

- Results of security reviews
- Resulting updates of the security test and review plan, if applicable

**prEN 40000-1-3 (E)****5.4.8.5 Assessment criteria**

- Evidence of reviews being performed based on the information source defined
- Evidence of updates to the security test and review plan, if applicable

**5.5 [VRF] Verification****5.5.1 General**

The verification phase, often referred to as triage, includes requirements for determining whether the reported vulnerability affects the product. It also includes requirements for prioritizing the vulnerability based on vulnerability risk assessment activities.

The primary objective of this phase is to assess the validity, reproducibility, and applicability of the reported vulnerability. During this phase, the received information is reviewed to determine whether it is complete and whether the vulnerability is genuine and applicable to the product in question. If a vulnerability is assessed as relevant, the security risk analysis is performed to determine whether the risk associated with the vulnerability is to be mitigated and, if so, with what priority.

NOTE 1 During Multi-party coordinated vulnerability (MPCVD) consider the guidance provided by [ISO/IEC TR 5895:2022 \[4\]](#), 9.2.

NOTE 2 Whereas *[VRF-1] Initial assessment and verification* and *[VRF-2] Vulnerability risk assessment* are separated, all the activities listed can occur in parallel rather than in a sequential order.

**5.5.2 [VRF-1] Initial assessment and verification****5.5.2.1 General**

The clause describes the initial assessment and verification of the vulnerability report. The primary objective of this phase is to assess the validity, reproducibility, and applicability of reported vulnerabilities. The manufacturer evaluates the credibility and information provided in the report, attempts to reproduce the issue, assesses its impact on the affected product, and assesses the severity of the vulnerability. This step ensures that only verified vulnerabilities proceed to the security risk assessment.

**5.5.2.2 Input**

- Vulnerability information from [5.4.3](#)
- Product security architecture and design, see [prEN 40000-1-2:2025 \[16\]](#), 7.4
- List of software and hardware components, see sections [5.3.8](#) and [5.3.9](#)
- Product context, see [prEN 40000-1-2:2025 \[16\]](#), 6.2
- Product risk assessment, see [prEN 40000-1-2:2025 \[16\]](#), 6.4

**5.5.2.3 Requirement**

**[VRF-1-RQ-01]** More information shall be requested from the reporter if the available information is insufficient.

**[VRF-1-RQ-02]** An assessment of the vulnerability shall be performed.

NOTE For additional guidance related to this requirement, refer to [EN ISO/IEC 30111:2020 \[2\]](#)

- 7.1.4 a)
- 7.1.4 b)
- 7.1.4 c)

- 7.1.4 d)

#### 5.5.2.4 Output

- Documentation on processing the vulnerability information

NOTE This can include:

- Rationale for vulnerabilities that were determined as not applicable
- A tracked, verified vulnerability report including an assessment of the vulnerability and its severity

#### 5.5.2.5 Assessment criteria

- Evidence that activities of vulnerability investigations have been performed
- Evidence that information and status are tracked as required by [5.4.3](#)
- Evidence exists that the severity has been determined

### 5.5.3 [VRF-2] Vulnerability risk assessment

#### 5.5.3.1 General

This clause describes the activities of conducting a risk assessment to determine the potential risk posed by a verified vulnerability, thereby prioritizing the vulnerability handling process. The risk assessment is based on the product's established risk management framework, ensuring that the results are consistent with the overall risk evaluation methodology applied to the product [[prEN 40000-1-2 \[1\]](#)].

#### 5.5.3.2 Input

- Verified vulnerability report, including an assessment of the vulnerability and severity.
- Risk assessment ([prEN 40000-1-2:2025 \[16\]](#), 6.4)

#### 5.5.3.3 Requirement

**[VRF-2-RQ-01]** The risk introduced by the vulnerability shall be assessed in accordance with prEN 40000-1-2:2025, 6.4.

**[VRF-2-RQ-02]** The priority shall be assigned to the vulnerability based on the risk assessment referenced in [VRF-2-RQ-01] and the product risk profile.

NOTE 1 For additional guidance related to the prioritization, refer to [EN ISO/IEC 30111:2020 \[2\]](#), 7.1.4 e)

**[VRF-2-RQ-03]** If the determination of the risk of the vulnerability as per [VRF-2-RQ-02] exceeds the defined threshold by the manufacturer's risk assessment, the resolution of the vulnerability shall be expedited.

NOTE 2 *In relation to the expedited definition within this document*

The process of accelerating one or more vulnerability handling activities (e.g. remediation development, testing, release) outside the normal update cycle.

**[VRF-2-RQ-04]** If the vulnerability information source is from a coordinated vulnerability disclosure, then the reporter shall be informed about the results of the verification.

NOTE 3 For additional guidance related to this requirement refer to [EN ISO/IEC 30111:2020 \[2\]](#), 7.1.4 f).

NOTE 4 If the vulnerability information relates to a third-party component, then the person or entity manufacturing or maintaining that component can be informed about the results of the verification with respect to that component.

**prEN 40000-1-3 (E)****5.5.3.4 Output**

- Documented outcome of the priority assessment
- Communication with the reporter, if applicable

**5.5.3.5 Assessment criteria**

- Evidence of the communication with the reporter, if applicable
- Evidence of prioritization of the vulnerability

**5.6 [RMD] Remediation****5.6.1 General**

This phase includes decision making activities to mitigate cybersecurity risks associated with the verified vulnerability. This includes identifying appropriate fixes, planning, development, testing for effectiveness and compatibility, and preparing updates or mitigations for deployment.

NOTE During multi-party coordinated vulnerability (MPCVD) consider the guidance provided by [ISO/IEC TR 5895:2022 \[4\]](#), 9.3.

**5.6.2 [RMD-1] Remediation decision****5.6.2.1 General**

This phase includes the decision-making activities for mitigating the cybersecurity risks related to the verified vulnerability. It involves selecting and assessing risk remediation measures, evaluating their feasibility, and considering the potential impact on the product, users, and other stakeholders. Based on this analysis, the manufacturer determines the most appropriate remediation, which can include an update, intermediate mitigation, or a justified decision to defer or decline remediation.

**5.6.2.2 Input**

- Prioritized vulnerabilities as per [5.5.3](#)

**5.6.2.3 Requirement**

**[RMD-1-RQ-01]** A decision on how to remediate the vulnerability shall be taken.

NOTE For additional guidance related to the remediation decision requirement, refer to [EN ISO/IEC 30111:2020 \[2\]](#), 7.1.5 a).

**[RMD-1-RQ-02]** In accordance with the decision in [RMD-1-RQ-01], subsequent actions shall be planned, including the definition of the timeline for the remediation.

**5.6.2.4 Output**

- Documented decision on how to remediate the vulnerability
- Documented remediation plan, including the timeline

**5.6.2.5 Assessment criteria**

- Evidence of the documented decision
- Evidence of the remediation plan, including the timeline

**5.6.3 [RMD-2] Remediation development**

### 5.6.3.1 General

After the decision to remediate a particular vulnerability has been taken and planned, it is essential to perform the activities that produce the remediation. During these activities, the manufacturer could produce updates, documentation, or configuration changes, as appropriate, to address a vulnerability.

These activities can involve third parties, including suppliers and open-source projects, to coordinate the development or source existing remediation.

### 5.6.3.2 Input

- Decision on remediation of the vulnerability
- Remediation plan, including the timeline

### 5.6.3.3 Requirement

**[RMD-2-RQ-01]** The remediation shall be produced.

NOTE 1 The development of the remediation follows the internal processes defined by the manufacturer as per [prEN 40000-1-2:2025 \[16\]](#), Clause 7.

NOTE 2 For additional guidance related to remediation development requirement, refer to [EN ISO/IEC 30111:2020 \[2\]](#), 7.1.5. b).

NOTE 3 Existing remediation from third parties can be used to address the vulnerability.

NOTE 4 Remediation development can include any artefact that addresses the vulnerability. For example, updating user documentation.

**[RMD-2-RQ-02]** Security updates shall be provided separately from functional updates, where technically feasible.

NOTE 5 Technical feasibility: the degree to which the proposed system design and architecture can be implemented using available technology, within constraints such as cost, schedule, and performance.

NOTE 6 Technical feasibility, can also consider operational feasibility, where the goal is to ensure the solution can be effectively integrated, maintained, and supported.

### 5.6.3.4 Output

- Produced remediation and related documentation

### 5.6.3.5 Assessment criteria

- Evidence of a produced remediation and related documentation

## 5.6.4 [RMD-3] Remediation test

### 5.6.4.1 General

This subclause describes the activities to develop and perform appropriate tests to ensure that the risks associated with a vulnerability are mitigated without a negative impact on the product or users.

### 5.6.4.2 Input

- Remediation decision
- Produced remediation and related documentation

**prEN 40000-1-3 (E)****5.6.4.3 Requirement**

**[RMD-3-RQ-01]** The remediation shall be tested to ensure the risks related to the vulnerability are mitigated and the impact on the product and the users is acceptable.

NOTE 1 For additional guidance on testing of remediation, refer to [prEN 40000-1-2:2025 \[16\]](#), 7.6.

NOTE 2 For additional guidance related to the remediation test requirement, refer to [EN ISO/IEC 30111:2020 \[2\]](#), 7.1.5 c).

NOTE 3 When remediation originates from third parties, the manufacturer will, to the extent reasonably practicable, verify the remediation at the product level and confirm functional performance; full underlying component verification is performed by the supplier.

**5.6.4.4 Output**

- Remediation test report
- Tested remediation

**5.6.4.5 Assessment criteria**

- Evidence of the remediation test report
- Tested remediation exists

**5.7 [RLS] Release****5.7.1 General**

The release phase includes requirements for deploying and sharing remediation, describing associated changes, and disseminating remediation information to relevant stakeholders.

**5.7.2 [RLS-1] Security update release****5.7.2.1 General**

This subclause addresses the activities of gathering all the artefacts to address vulnerabilities and disseminating security updates.

Any delay in applying security updates gives attackers time to exploit the product's vulnerabilities. Therefore, the timely distribution of security updates is essential. A secure update distribution mechanism ensures the integrity and authenticity of security updates. An automatic update distribution mechanism ensures that vulnerabilities are remediated without user interaction for the products that support automatic updates.

Such updates need to be provided in a secure manner, which might, for example, use digital signatures and/or secure download services.

Security updates are to be applied automatically or manually depending on the type of product, its technical implementation, its intended purpose, and its reasonably foreseeable use.

Providing security updates that do not change the product's other functionality reduces the risk of unintended or unwanted operational impacts in the user's environment. On the other hand, some remediations require significant changes that cannot be implemented without larger interventions into the product.

**5.7.2.2 Input**

- Tested security update or remediation as required per [5.6.4](#)

### 5.7.2.3 Requirement

**[RLS-1-RQ-01]** Security updates shall be provided, unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements, free of charge.

**[RLS-1-RQ-02]** Once a security update is provisioned, it shall be distributed in a timely manner.

NOTE 1 "Timely" in this context means that security updates that fix a critical vulnerability (i.e. risk for societal impact) are handled with appropriate priority by the manufacturer as established in [5.5.3](#).

NOTE 2 Expedite software updates to address critical security vulnerabilities.

NOTE 3 There are several distribution mechanisms, including automatic or manual. The product and infrastructure design need to provide an adequate distribution mechanism, taking into account the product's intended purpose and target users.

NOTE 4 For additional guidance for the distribution, refer to [prEN 40000-1-2:2025 \[16\]](#), 7.7.

**[RLS-1-RQ-03]** Installation instructions shall be provided for security updates unless distribution is fully automated.

**[RLS-1-RQ-04]** The mechanisms to distribute security updates shall ensure their authenticity and integrity.

### 5.7.2.4 Output

- Distribution of security update
- Installation instructions resulting from [RLS-1-RQ-03]

### 5.7.2.5 Assessment criteria

- Evidence of security update distribution
- Evidence of implemented security update mechanisms for secure distribution of security updates.
- Evidence of the implementation of automatic security update distribution mechanism for products capable of being automatically updated.
- Evidence of installation instructions

## 5.7.3 [RLS-2] Release information

### 5.7.3.1 General

This phase describes a process for publishing information about resolved vulnerabilities and the distribution of corresponding security updates. It includes detailed guidance on communication, publication, and coordination with users and other stakeholders. Publications such as advisories or release notes provide clear, comprehensive documentation to help understand the nature of the vulnerabilities and manage associated risks effectively.

### 5.7.3.2 Input

- Tested security update as required per [5.6.4](#)
- Policy on coordinating vulnerability disclosure (CVD)

### 5.7.3.3 Requirement

**[RLS-2-RQ-01]** Information of fixed vulnerabilities shall be published in accordance with the policy on coordinating vulnerability disclosure (CVD) as required by [PRE-2-RQ-01], and where appropriate, this information can be summarized or aggregated.

**prEN 40000-1-3 (E)**

NOTE 1 For additional guidance on publishing vulnerability advisories, refer to [EN ISO/IEC 29147:2020 \[3\]](#), Clause 7.

**[RLS-2-RQ-02]** The publication shall contain at least, but not limited to, the following information to enable the target audience to decide if the vulnerabilities are relevant and how to remediate them:

- description of the vulnerability;
- vulnerability identifier;
- information allowing the identification of the affected product;
- potential impact of the vulnerability;
- severity of the vulnerability;
- detailed information on how to remediate the vulnerability;
- release date and update date.

NOTE 2 For additional guidance on advisory elements, refer to [EN ISO/IEC 29147:2020 \[3\]](#), 7.4.

**[RLS-2-RQ-03]** Information regarding fixed vulnerabilities shall be made available in a human-readable format.

**[RLS-2-RQ-03-RE]** Information regarding fixed vulnerabilities shall be made available in a widely recognized machine-readable format.

NOTE 3 Machine-readable format is specified in [ISO/IEC 20153:2025 \[17\]](#).

**[RLS-2-PM-01]** To give sufficient time to distribute the security update, full publication according to *[RLS-2-RQ-02]* may be delayed if all the following conditions apply:

- An evaluation determines that the security risks of full publication outweigh the security benefits.
- Information about a vulnerability fixed by the security update is made available to users in such a way that an attacker could not use this information to exploit the vulnerability.
- Product users are informed about the date of public disclosure of all vulnerability information, as required per *[RLS-3-RQ-02]*.

**[RLS-2-RC-01]** Vulnerability information from *[RLS-2-RQ-01]* should be made publicly available on the EU Vulnerability Database (EUVD).

NOTE 4 If vulnerability information is disclosed through the CVE program, EUVD automatically adds it to its database.

#### **5.7.3.4 Output**

- Publicly disclosed information on vulnerabilities addressed by the security update
- Rationale for delaying publication

#### **5.7.3.5 Assessment criteria**

- Evidence of published information on vulnerabilities addressed by the security update
- Evidence of published machine-readable information on vulnerabilities addressed by the security update, if applicable
- Evidence of published information on vulnerabilities addressed by the security update at EUVD, if applicable
- Evidence of information on publication delay, where permission *[RLS-2-PM-01]* was utilized

## 5.8 [PRA] Post-release

### 5.8.1 General

The post-release phase focuses on activities that occur after the remediation and release of a vulnerability. It includes requirements for monitoring released security updates, capturing lessons learned, and reflecting on the post-release process to inform and improve future development practices.

### 5.8.2 [PRA-1] Post-release actions

#### 5.8.2.1 General

This phase is crucial for ensuring the ongoing quality and effectiveness of the remediation. The manufacturer has the discretion to apply this action in a way that enables continuous improvement of their product-related processes.

#### 5.8.2.2 Input

- Tracked and prioritized list of vulnerabilities with their assessed risks
- Vulnerability remediation

#### 5.8.2.3 Requirement

**[PRA-1-RQ-01]** Post-release actions shall be carried out, including:

- Case maintenance
- Monitoring of remediation

NOTE 1 Monitoring of remediation can be part of the overall [5.4.3](#).

NOTE 2 For additional guidance on post-release, refer to [EN ISO/IEC 30111:2020 \[2\]](#), 7.1.7.

#### 5.8.2.4 Output

- Documentation of post-release actions and related plan

#### 5.8.2.5 Assessment criteria

- Evidence of post-release actions exists
- Evidence on the execution of the post-release actions as specified in [PRA-RQ-01]

## Annex ZA (informative)

### Relationship between this European Standard and the essential cybersecurity requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) aimed to be covered

This European Standard has been prepared under a Commission's standardization request C(2025)618 ('M/606')<sup>1</sup> to provide one voluntary means of conforming to the essential cybersecurity requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once this standard is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of this standard given in [Table ZA.1](#) confers, within the limits of the scope of this standard, a presumption of conformity with the corresponding essential cybersecurity requirements of that Regulation, and associated EFTA regulations.

Where a definition in this standard differs from a definition of the same term set out in Regulation (EU) 2024/2847, the differences shall be indicated in this Annex Z. Where a reference from a clause of this standard to risk assessment is made, the risk assessment process needs to be in compliance with Regulation (EU) 2024/2847. For the purpose of using this standard in support of the requirements set out in Regulation (EU) 2024/2847, the definitions set out in the Regulation prevail.

**Table ZA.1 — Correspondence between this European Standard and Annex I of the Cyber Resilience Act**

| Essential cybersecurity requirements of Regulation (EU) 2024/2847 | Clause(s)/sub-clause(s) of this EN                                                                                                                                                                                                                                    | Remarks/Notes |
|-------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|
| Annex I, Part 2, (1)                                              | <a href="#">5.3.7</a> , <a href="#">5.3.8</a> , <a href="#">5.3.9</a> , <a href="#">5.4.3</a> , <a href="#">5.4.4</a> , <a href="#">5.4.5</a>                                                                                                                         |               |
| Annex I, Part 2, (2)                                              | <a href="#">5.3.2</a> , <a href="#">5.3.4</a> , <a href="#">5.3.5</a> , <a href="#">5.4.6</a> , <a href="#">5.5.2</a> , <a href="#">5.5.3</a> , <a href="#">5.6.2</a> , <a href="#">5.6.3</a> , <a href="#">5.6.4</a> , <a href="#">5.7.2</a> , <a href="#">5.8.2</a> |               |
| Annex I, Part 2, (3)                                              | <a href="#">5.3.10</a> , <a href="#">5.4.3</a> , <a href="#">5.4.7</a> , <a href="#">5.4.8</a> , <a href="#">5.8.2</a>                                                                                                                                                |               |
| Annex I, Part 2, (4)                                              | <a href="#">5.3.7</a> , <a href="#">5.7.3</a>                                                                                                                                                                                                                         |               |
| Annex I, Part 2, (5)                                              | <a href="#">5.3.3</a>                                                                                                                                                                                                                                                 |               |
| Annex I, Part 2, (6)                                              | <a href="#">5.3.6</a> , <a href="#">5.4.2</a>                                                                                                                                                                                                                         |               |
| Annex I, Part 2, (7)                                              | <a href="#">5.7.2</a> , <a href="#">5.3.11</a> , <a href="#">5.5.3</a> , <a href="#">5.8.2</a>                                                                                                                                                                        |               |
| Annex I, Part 2, (8)                                              | <a href="#">5.3.11</a> , <a href="#">5.7.2</a> , <a href="#">5.7.3</a>                                                                                                                                                                                                |               |

**WARNING** Presumption of conformity stays valid only as long as a reference to this European Standard is maintained in the list published in the Official Journal of the European Union. Users of this standard should consult frequently the latest list published in the Official Journal of the European Union.

**WARNING** Other Union legislation may be applicable to the products falling within the scope of this standard

<sup>1</sup> COMMISSION IMPLEMENTING DECISION of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

## Bibliography

- [1] prEN 40000-1-2, *Cybersecurity requirements for products with digital elements - Part 1-2: Principles for cyber resilience*
- [2] EN ISO/IEC 30111:2020, *Information technology - Security techniques - Vulnerability handling processes (ISO/IEC 30111:2019)*
- [3] EN ISO/IEC 29147:2020, *Information technology - Security techniques - Vulnerability disclosure (ISO/IEC 29147:2018)*
- [4] ISO/IEC TR 5895:2022, *Cybersecurity — Multi-party coordinated vulnerability disclosure and handling*
- [5] ISO/IEC/IEEE 29119-2:2021, *Software and systems engineering — Software testing — Part 2: Test processes*
- [6] ISO 31073:2022, *Risk management — Vocabulary*
- [7] ISO 28001:2007, *Security management systems for the supply chain — Best practices for implementing supply chain security, assessments and plans — Requirements and guidance*
- [8] ISO/IEC 29147:2018, *Information technology — Security techniques — Vulnerability disclosure*
- [9] EN 301 549 v3.2.1, *Accessibility requirements for ICT products and services*
- [10] prEN IEC 61360-7:2025, *Standard data element types with associated classification scheme - Part 7: Data dictionary of cross-domain concepts*
- [11] BSI TR-03183:v2.1 *Cyber Resilience Requirements for Manufacturers and Products - Part 2: Software Bill of Materials (SBOM)*
- [12] ISO/IEC 27036-3:2023, *Cybersecurity — Supplier relationships — Part 3: Guidelines for hardware, software, and services supply chain security*
- [13] ISO/IEC 5962:2021, *Information technology — SPDX® Specification V2.2.1*
- [14] ISO 8601-1:2019, *Date and time — Representations for information interchange — Part 1: Basic rules*
- [15] RFC 9116:2022, *A File Format to Aid in Security Vulnerability Disclosure*
- [16] prEN 40000-1-2:2025, *Cybersecurity requirements for products with digital elements - Part 1-2: Principles for cyber resilience*
- [17] ISO/IEC 20153:2025, *Information technology — OASIS Common Security Advisory Framework (CSAF) v2.0 Specification*

Ontwerp  
Draft

**Why do you have to pay for a standard?**

Standards are agreements for and by the market. They are agreements about matters that concern everyone, e.g. about healthcare, financial services, safety and corporate social responsibility. Life would be a lot more complex without these agreements. Standards improve products, services and processes in the workplace, in our interactions with each other, and in society as a whole.

The agreements are made by interested parties. An interested party can be a producer, entrepreneur, service provider or user, but it can also be a government authority, a consumer association or a research organization. Broad support is important. The agreements are made with support from NEN, and they must not conflict with any other valid NEN standards.

NEN is a non-profit foundation. The services provided by NEN – from bringing parties together and making and recording the agreements, to providing assistance when applying the standards – cost money. That is why all the participating parties pay for the standardization process and you, as a user, pay for the standards, training courses and other products.

Ontwerp  
Draft

Ontwerp  
Draft